



ACTIONS ON CYBER

— PRACTICAL GUIDANCE. REAL PROTECTION. —
READY TODAY. SECURE TOMORROW.

NIST CSF ALIGNED

CYBER SECURITY GOVERNANCE POLICY

NIST CSF Alignment: Govern

Defines cyber security ownership, decision-making, oversight, reporting and policy expectations.

Document type: Policy template | Version: 1.0

Audience: Small and medium-sized organisations

Review frequency: Annual, or after a major business, technology, supplier or threat change

ACTIONS ON CYBER

Practical Guidance. Real Protection. Ready Today. Secure Tomorrow.

Cyber Security Governance Policy

Template status: standalone starter policy for the Actions on Cyber Field Manual.

Disclaimer

This template is a starting point only. It is not legal advice and should be adapted to the organisation, sector, operating model, risk profile, contractual duties and regulatory obligations.

Document control

Field	Suggested wording
Policy owner	[Insert role, for example Managing Director, Operations Director, Head of IT or Cyber Lead]
Approved by	[Insert approving body, for example Board, Trustees or Senior Leadership Team]
Version	1.0
Effective date	[Insert date]
Next review date	[Insert date]
NIST CSF alignment	Govern - organisational context, risk strategy, roles, responsibilities, policy and oversight

Contents

- 1. Purpose
- 2. Scope
- 3. Governance principles
- 4. NIST CSF alignment
- 5. Policy statements
- 6. Roles and responsibilities
- 7. Governance forums and reporting
- 8. Policy management and exceptions
- 9. Assurance and evidence
- 10. Review and continual improvement
- Appendix A. Governance checklist
- Appendix B. Suggested leadership reporting pack

1. Purpose

The purpose of this policy is to define how cyber security is governed across the organisation. It sets out ownership, accountability, decision-making, oversight and reporting expectations so that cyber security is managed as a business risk rather than only a technical issue.

This policy provides a simple governance baseline for small and medium-sized organisations. It should be supported by practical procedures, risk registers, incident response plans, supplier security reviews and security awareness activities.

2. Scope

This policy applies to all business systems, information assets, cloud services, suppliers, devices, networks, users, data and business processes that create, access, store, process or transmit organisational information.

It applies to employees, contractors, temporary workers, suppliers and any other party who has access to organisational systems, data or services.

3. Governance principles

- Cyber security risks should be visible to leadership and considered alongside operational, financial, legal, regulatory and reputational risks.
- Accountability should be clear. Every material risk, policy, system and supplier relationship should have an accountable owner.
- Security decisions should be proportionate to the size of the organisation, sensitivity of data and potential business impact.
- Security controls should support the organisation in operating safely, not unnecessarily block business activity.
- Cyber governance should be reviewed regularly and improved using lessons from incidents, audits, exercises and changes in the threat landscape.

4. NIST CSF alignment

This policy is aligned to the NIST Cybersecurity Framework function of Govern. It provides the management foundation for the other NIST CSF functions: Identify, Protect, Detect, Respond and Recover.

NIST CSF Function	How this policy supports it
Govern	Defines cyber security ownership, risk oversight, policy expectations, leadership reporting and management review.
Identify	Requires assets, services, suppliers, data and cyber risks to be understood and owned.
Protect	Requires leadership to approve and oversee protective control expectations such as access control, backups, training and supplier access.
Detect	Requires oversight of logging, monitoring, vulnerability information and security event reporting.
Respond	Requires clear escalation routes, incident ownership, communications and decision-making during incidents.
Recover	Requires business recovery priorities, lessons learned and continual improvement after disruption.

5. Policy statements

The following policy statements define the minimum cyber security governance expectations for the organisation.

- The organisation must assign a named senior owner for cyber security governance.
- Cyber security risks must be recorded, owned, assessed, treated, accepted or escalated through an agreed risk management process.
- Cyber security policies must be approved, communicated, reviewed and made available to relevant users.
- Leadership must receive regular reporting on material cyber risks, incidents, control gaps and overdue remediation actions.
- Critical systems, sensitive data, key suppliers and important business services must have named owners.
- Major technology, supplier, data, AI or process changes must consider cyber security risk before implementation.
- Security incidents must be reported promptly and managed through an agreed incident response process.
- Exceptions to cyber security policy must be documented, risk assessed, approved, time-limited and reviewed.
- The organisation must retain proportionate evidence that key cyber security controls are operating.
- Cyber security governance arrangements must be reviewed at least annually and after significant incidents or business changes.

6. Roles and responsibilities

Role	Responsibilities
Board, trustees or owners	Approve cyber governance expectations, review material risks, confirm risk appetite and support investment decisions.
Senior accountable owner	Own the cyber security governance process, approve priorities and escalate material issues.
Cyber/security lead or IT lead	Maintain policies, advise on controls, coordinate risk assessment, support incidents and report control gaps.
System and service owners	Own risks, controls, user access, supplier dependencies and recovery expectations for their systems or services.
Supplier owners	Ensure suppliers are risk assessed, contracts include security expectations and supplier incidents are escalated.
People managers	Ensure staff complete training, follow policies and report incidents, risks or weaknesses.
All users	Use systems responsibly, protect information, follow policies and report suspected incidents promptly.

7. Governance forums and reporting

Cyber security should be reviewed through a regular management rhythm. Smaller organisations may use an existing leadership, risk or operations meeting rather than creating a separate cyber committee.

Forum or audience	Suggested frequency	Typical agenda items
Operational review	Monthly	Open risks, incidents, vulnerabilities, overdue actions, supplier changes, user access issues and upcoming changes.
Senior leadership review	Quarterly	Top cyber risks, control gaps, policy exceptions, incident trends, supplier risk, investment needs and key decisions.
Board, trustees or owners	Quarterly or biannual	Material cyber risk exposure, major incidents, regulatory concerns, assurance findings and strategic decisions.

Minimum leadership reporting content

- Top cyber risks and whether they are increasing, stable or reducing.
- Critical or overdue treatment actions requiring leadership support.
- Significant incidents, near misses or lessons learned.
- Policy exceptions, accepted risks and upcoming expiry dates.
- Supplier risks or security concerns affecting critical services.
- Metrics that show whether key controls are working, such as MFA coverage, backup test results and vulnerability remediation status.

8. Policy management and exceptions

Cyber security policies should be easy to find, written in plain language and reviewed on a defined schedule. Policy owners should ensure that policies remain relevant to the organisation and are not treated as shelfware.

Requirement	Expected approach
Approval	Policies should be approved by the appropriate senior owner or leadership forum.
Communication	Relevant users should be told what the policy means for their role.
Review	Policies should be reviewed at least annually or after major changes.
Exceptions	Exceptions should be documented, risk assessed, approved, time-limited and reviewed before expiry.
Retention	Old versions and approval records should be retained for audit and assurance purposes.

9. Assurance and evidence

The organisation should maintain proportionate evidence that cyber governance is operating. Evidence should be practical, useful and not overly bureaucratic.

Evidence item	Purpose
Approved cyber security policies	Shows that minimum expectations have been defined and authorised.
Cyber risk register	Shows that material cyber risks are recorded, owned and reviewed.
Leadership reporting pack	Shows that cyber risk is visible to decision-makers.
Incident log and post-incident reviews	Shows that incidents are tracked and lessons are captured.
Supplier security records	Shows that third-party risks are assessed and managed.
Access review records	Shows that access is periodically checked and inappropriate access is removed.
Backup and recovery test evidence	Shows that recovery arrangements are tested.
Training records	Shows that users receive appropriate awareness and guidance.

10. Review and continual improvement

This policy should be reviewed at least annually and after any significant security incident, major business change, technology change, supplier change, audit finding or change in legal or regulatory expectations.

Improvement actions should be tracked to completion. Lessons from incidents, tabletop exercises, vulnerability findings, supplier reviews and control testing should be used to update policies, risk records and control priorities.

Practical implementation note

For a small organisation, cyber governance does not need to be complex. A named owner, a risk register, a quarterly leadership review, clear policies and a tested incident response plan create a strong starting point.

Appendix A. Governance checklist

Use this checklist to review whether the minimum governance arrangements are in place.

Check	Yes / No / Notes
A senior owner is accountable for cyber security governance.	
Cyber security policies are approved and available to relevant users.	
A cyber risk register exists and has named owners for material risks.	
Top cyber risks are reviewed by leadership on a regular cycle.	
Critical systems, data sets and suppliers have named owners.	
Policy exceptions and accepted risks are documented and time-limited.	
Security incidents are logged and reviewed for lessons learned.	
Suppliers with access to data or systems are security assessed.	
MFA, backup, vulnerability and access review status are reported.	
This policy has an owner, version number and next review date.	

Appendix B. Suggested leadership reporting pack

A simple leadership reporting pack can be one or two pages. It should show what matters, what is changing and where a decision is needed.

Section	Suggested content
Executive summary	Overall cyber risk position and main changes since the last report.
Top risks	Top five cyber risks, owners, ratings, treatment status and decisions required.
Control health	MFA coverage, backup test status, critical vulnerabilities, access review completion and training completion.
Incidents and near misses	Significant incidents, themes, lessons and open actions.
Supplier risk	High-risk suppliers, overdue reviews, supplier incidents and contract concerns.
Decisions required	Investment, risk acceptance, policy exception or prioritisation decisions needed from leadership.

Document end

Tailor this policy before use. Replace bracketed fields, align ownership to your operating model and link this policy to your risk register, incident response plan and supplier security process.